Controlled proof and selective fix verification

Assessment

Title

Controlled proof and selective fix verification

Assessment ID

reproducible-local-assessment

Reviewer

AuthzLedger synthetic fixture

Period

Retained execution timestamps

Snapshot

6792337b8aa67b6edcfd4e5f1c6aa83bfa89f249ec3a77e9cd036ce937cf3478

Renderer

assessment-html-pdf-v1-reportlab-4.4.9-dejavu-2.37

Executive summary

Summary

Evidence-backed assessment of explicitly selected security rules.

Finding status

{"candidate": 0, "confirmed": 0, "rejected": 0, "retest_pending": 1, "retest_verified": 1}

Scope and methodology

Scope

http://127.0.0.1:45833

Method

Explicit rules, source-bound requests and valid controls. Evidence remains local; observations are reviewed at their recorded verification level.

Coverage

[{"comparison_sha256": "eb306f068755d96036c214661ff2723f68a434749c63e032dbb3cee3ed22e5af", "dependency_cases": 3, "not_retested_cases": 1, "retested_cases": 4, "selected_cases": 1, "source_cases": 5}]

Tenant B must not receive Tenant A invoice content

Finding ID

finding-c05b584f5c488a0155a3397e

Status

retest_pending

Execution record status

confirmed

Interpretation

violation

Category

denial_data_disclosure

Rule digest

b998c742eb0fa660c51a813c5b9a5aecf3385cdd950a870bbb839b48036eb11f

Resource

invoice-a

Identity

peer

Case

variant-peer-2

Reproduction

GET /invoices/a as peer; execute controls before this case. Use the retained source contract and environment/session credential references.

Expected checks

{"json_absent": ["/protected_marker"], "status": [401, 403, 404]}

Observation

[{"body_complete": true, "controls_valid": true, "interpretation": "violation", "status": 403, "verification_level": "captured_inputs_replayed"}]

Controls

actor-identity-0, known-denial-0, owner-object

Evidence

9683c5016383189ebeec0f82eed13eafa25c2f1ea3c41e0b1c3e7e30aa4193c3

Source report root

f934c710cb14c528fead05985c68fb2430b7101e24bb7b9d30a69fd5622d74b2

Finding record digest

d2704c9aa5db92bf31a2c42433fcafefb995092f74e375d97b7a4c7349f61ccd

Verification level

captured_inputs_replayed

Impact

The configured protected marker was disclosed to the tested identity.

Remediation

Enforce the configured rule at the resource and response boundary; rerun this experiment with fresh controls.

Business risk

Not assessed by reviewer

CVSS 4.0

not_scored; vector: not supplied

Retest

[{"baseline_root": "f934c710cb14c528fead05985c68fb2430b7101e24bb7b9d30a69fd5622d74b2", "case_id": "variant-peer-2", "comparison_digest": "f20611e4c7f815de6d1a70efe4bacc9cbadbaebcc16c110a7e6d6afc22eb665c", "comparison_sha256": "eb306f068755d96036c214661ff2723f68a434749c63e032dbb3cee3ed22e5af", "current_root": "ce1c27054af8992bf8ea7a27b53c44d3978a5227c5f0e2139b53e7a810a9a1a3", "finding_status": "not_retested", "status": "not_retested"}]

Standards mapping

No requirement-level mapping reviewed.

Limitations

Remote response authenticity is not established by local signing.
Only selected oracle inputs are replayed; their projection from the omitted raw body remains signer-attested.

Tenant B must not receive Tenant A invoice content

Finding ID

finding-cabbe355c68937e2311bb886

Status

retest_verified

Execution record status

rejected

Interpretation

satisfied

Category

authorization_rule_violation

Rule digest

b998c742eb0fa660c51a813c5b9a5aecf3385cdd950a870bbb839b48036eb11f

Resource

invoice-a

Identity

peer

Case

variant-peer-1

Reproduction

GET /invoices/a as peer; execute controls before this case. Use the retained source contract and environment/session credential references.

Expected checks

{"json_absent": ["/protected_marker"], "status": [401, 403, 404]}

Observation

[{"body_complete": true, "controls_valid": true, "interpretation": "satisfied", "status": 403, "verification_level": "captured_inputs_replayed"}]

Controls

actor-identity-0, known-denial-0, owner-object

Evidence

19dd22c9fcdd19fc04547d0e5823a1ee3e311fd55e19f682ef5aa7c19ce3dd15

Source report root

ce1c27054af8992bf8ea7a27b53c44d3978a5227c5f0e2139b53e7a810a9a1a3

Finding record digest

20941ae496292ec1cd51141c27449b0483e00d8ee626f43b0abd612feb62fe39

Verification level

captured_inputs_replayed

Impact

Limited to the explicitly evaluated predicate; business impact requires review.

Remediation

Enforce the configured rule at the resource and response boundary; rerun this experiment with fresh controls.

Business risk

Not assessed by reviewer

CVSS 4.0

not_scored; vector: not supplied

Retest

[{"baseline_root": "f934c710cb14c528fead05985c68fb2430b7101e24bb7b9d30a69fd5622d74b2", "case_id": "variant-peer-1", "comparison_digest": "f20611e4c7f815de6d1a70efe4bacc9cbadbaebcc16c110a7e6d6afc22eb665c", "comparison_sha256": "eb306f068755d96036c214661ff2723f68a434749c63e032dbb3cee3ed22e5af", "current_root": "ce1c27054af8992bf8ea7a27b53c44d3978a5227c5f0e2139b53e7a810a9a1a3", "finding_status": "fix_verified", "status": "resolved_check"}]

Standards mapping

No requirement-level mapping reviewed.

Limitations

Remote response authenticity is not established by local signing.
Only selected oracle inputs are replayed; their projection from the omitted raw body remains signer-attested.

Standards profile

API 2023

https://api-security.owasp.org/editions/2023/en/0x11-t10/

ASVS 5.0.0

https://github.com/OWASP/ASVS/tree/v5.0.0

CVSS 4.0

https://www.first.org/cvss/v4.0/specification-document

WSTG 4.2

https://wstg.owasp.org/v4.2/

Limitations and independent verification

Limitation

This is a scoped assessment, not certification or complete ASVS/WSTG/API coverage.

Limitation

Finding status, technical severity and business risk are separate dimensions.

Limitation

A restored configured check is not automatically a verified vulnerability fix.

Limitation

Retest omissions retain not_retested and historical evidence only.

Limitation

Signatures authenticate retained bytes and signing keys; they do not prove remote execution truth.

Limitation

Replayed oracle inputs are approved projections; their relationship to unavailable raw response bytes remains signer-attested.

Limitation

The standalone verifier provides integrity_only; semantic verification requires AuthzLedger and the pinned report renderer.

Limitation

Authored synthetic import fixture; this run is not a third-party exporter certification.

Limitation

A selected fix proves only the retained rule, identity, object and configured controls.

Verify

Obtain the public-key fingerprint through an independent trusted channel. Run: python3 -I verify_bundle.py PACKAGE --public-key TRUSTED.pem. The package manifest supplies the signer fingerprint. Then run AuthzLedger verify-bundle for retained evidence and exact report semantics. Never trust a key solely because it is inside the package.